

RECONNAISSANCE AND VULNERABILITY SCANNING REPORT

Project 1 - Authorized Local Lab Assessment

Prepared by

Sumit Saini

Cybersecurity Internship - Alfido Tech

Assessment date: 2 July 2026

Scope and authorization statement

All reconnaissance and vulnerability scans were performed only against a personally controlled Metasploitable 2 virtual machine (192.168.48.128) on an isolated VMware Host-Only network. No external or unauthorized systems were scanned, and no exploitation was performed.

Tools: Kali Linux | Nmap | Nikto | Metasploitable 2

1. Executive Summary

Purpose. This short assessment evaluated the exposed network services and web server configuration of the authorized Metasploitable 2 lab target. Nmap was used for port and service enumeration, and Nikto was used to assess the HTTP service for common web-server configuration weaknesses.

Summary of results. The target exposed multiple services, including anonymous FTP, Telnet, PostgreSQL, VNC, SMB, AJP, and Apache Tomcat. The web scan also identified outdated Apache and PHP versions, browsable directories, active HTTP TRACE, accessible phpinfo resources, phpMyAdmin-related files, and missing security headers.

2. Scope and Methodology

Scanner machine	Kali Linux virtual machine
Target machine	Metasploitable 2 virtual machine
Target IP address	192.168.48.128
Network boundary	VMware Host-Only network (isolated lab)
Nmap activity	Port / service enumeration using -sV and -sC
Nikto activity	HTTP web-server scan against port 80
Out of scope	Exploitation, password attacks, persistence, or scans of external systems

3. Risk Rating

- High - A finding that can directly enable unauthorized access, sensitive information exposure, or major service compromise if not remediated.
- Medium - A weakness that increases the attack surface or can support an attacker when combined with another issue.
- Low - A hardening issue with limited direct impact but useful for reducing security exposure.

Assessment boundary: Findings are based on the captured Nmap and Nikto outputs only. They should be validated and remediated according to the asset owner's change-management process in a real production environment.

4. Nmap Port and Service Enumeration

Command used: `sudo nmap -sV -sC -oN nmap_scan.txt 192.168.48.128`

Nmap confirmed that the host was reachable and identified a large exposed service footprint. The most important observations are summarized below.

ID	Finding	Evidence	Risk	Recommendation
N1	Anonymous FTP enabled	TCP/21 - vsftpd 2.3.4; anonymous login allowed	High	Disable anonymous FTP. Require named accounts, restrict directories, and use SFTP/SSH where possible.
N2	Telnet exposed	TCP/23 open	High	Disable Telnet because credentials and sessions can be transmitted in plain text. Use SSH instead.
N3	Multiple remote / database services exposed	PostgreSQL 5432, VNC 5900, X11 6000, IRC 6667, AJP 8009, Tomcat 8180	Medium	Disable unused services and restrict required ports to approved management networks with firewall rules.
N4	Weak SMB configuration	Nmap reported SMB signing disabled and guest-related information	Medium	Enable SMB signing, restrict guest access, and review SMB shares and account permissions.
N5	Legacy service versions detected	Older services such as OpenSSH 4.7p1 and Apache Tomcat 5.5 were observed	Medium	Maintain a patch inventory and upgrade or retire unsupported services.

Key observation: The scan reported anonymous FTP login on port 21. This can allow unauthenticated users to access FTP resources and should be removed unless there is a clearly justified business need with strict controls.

```

kali@kali: ~/alfido-project1
Session Actions Edit View Help
/home/kali/alfido-project1

(kali@kali)~(~/alfido-project1)
$ sudo nmap -sV -sC -oN nmap_scan.txt 192.168.48.128
Starting Nmap 7.98 ( https://nmap.org ) at 2026-07-01 14:50 -0400
Stats: 0:01:53 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 95.65% done; ETC: 14:52 (0:00:05 remaining)
Stats: 0:02:28 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 95.65% done; ETC: 14:52 (0:00:07 remaining)
Stats: 0:02:38 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 95.65% done; ETC: 14:53 (0:00:07 remaining)
Stats: 0:02:51 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 99.35% done; ETC: 14:53 (0:00:00 remaining)
Stats: 0:03:13 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 84.57% done; ETC: 14:53 (0:00:01 remaining)
Stats: 0:03:24 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 86.17% done; ETC: 14:53 (0:00:03 remaining)
Stats: 0:03:42 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 92.55% done; ETC: 14:54 (0:00:03 remaining)
Nmap scan report for 192.168.48.128
Host is up (0.0023s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
|_ftp-syst:
|_STAT:
|_FTP server status:
|_Connected to 192.168.48.129
|_Logged in as ftp
|_TYPE: ASCII
|_No session bandwidth limit
|_Session timeout in seconds is 300
|_Control connection is plain text
|_Data connections will be plain text
|_vsFTPd 2.3.4 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ssh-hostkey:
|_1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)

```

Figure 1. Nmap evidence showing the command, target IP address, and exposed FTP, SSH, Telnet, and SMTP services.

5. Nikto Web Vulnerability Scan

Target scanned: http://192.168.48.128 (TCP/80) | **Output file:** nikto_scan.txt

Nikto identified outdated web software, insecure HTTP behavior, information exposure, and several web-server hardening gaps. These items are listed below.

ID	Finding	Evidence	Risk	Recommendation
W1	Outdated Apache and PHP	Apache/2.2.8 and PHP/5.2.4 identified	High	Upgrade to supported versions and apply security patches through the approved maintenance process.
W2	Sensitive information exposure	phpinfo.php, phpMyAdmin pages, and a phpMyAdmin ChangeLog were detected	High	Remove or restrict diagnostic pages; protect database administration tools with authentication, network restrictions, and MFA.
W3	Directory indexing enabled	/icons/, /doc/, and /test/ reported as browsable	Medium	Disable directory listing and remove non-production files and sample/test content.
W4	HTTP TRACE enabled	Nikto reported TRACE as active	Medium	Disable the TRACE method unless there is a documented business requirement.
W5	Security headers missing	HSTS, CSP, Referrer-Policy, X-Content-Type-Options, Permissions-Policy	Medium	Configure appropriate HTTP response headers after application compatibility testing.
W6	Apache MultiViews enabled	MultiViews / content negotiation identified	Low	Disable MultiViews when not needed to reduce file-name discovery and unintended content mapping.

```

kali@kali: ~/alfido-project1
Session Actions Edit View Help

-Security
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [999100] /index: Uncommon header(s) 'tcn' found, with contents: list.
+ [999965] /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following files or 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/1000000
+ [999967] /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ [000434] /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/HTTP_Tracing
+ [750510] /phpinfo.php: Output from the phpinfo() function was found.
+ [750500] /doc/: Directory indexing found.
+ [001213] /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678
+ [001384] /?PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP Easter Eggs reveals potentially sensitive information via HTTP requests that contain PHP strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-your-php-easter-egg/
+ [001385] /?PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain PHP strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-your-php-easter-egg/
+ [001386] /?PHPE9568F34-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain PHP strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-your-php-easter-egg/
+ [001387] /?PHPE9568F35-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain PHP strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-your-php-easter-egg/
+ [001795] /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ [999984] /phpMyAdmin/ChangeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin/ChangeLog, inode: 92462, size: 40540
+ [001796] /phpMyAdmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ [750500] /test/: Directory indexing found.
+ [001894] /test/: This might be interesting.
+ [002989] /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ [003584] /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ [007107] /phpMyAdmin/README: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ [007342] /: X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP header with the frame-ancestors directive. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
+ [007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/

```

Figure 2. Nikto evidence showing reported web-server configuration and information-exposure findings, including accessible phpinfo and browsable directories.

6. Prioritized Remediation Plan

Priority 1 - Immediate: Disable anonymous FTP and Telnet. Restrict or disable unnecessary exposed services. Restrict phpMyAdmin and remove phpinfo/test content from production-like systems.

Priority 2 - Short term: Patch or upgrade Apache, PHP, Tomcat, SSH, database, and remote-access services. Enable SMB signing and review guest access.

Priority 3 - Hardening: Disable directory listing, HTTP TRACE, and unused MultiViews. Implement required HTTP security headers after testing.

Priority 4 - Ongoing: Maintain an asset inventory, scan regularly, review firewall rules, and monitor public-facing or administrative services for unusual activity.

7. Conclusion

The authorized assessment found multiple exposed services and web-server hardening weaknesses on the Metasploitable 2 lab target. The most significant issues were anonymous FTP access, Telnet exposure, outdated Apache/PHP software, information exposure through phpinfo/phpMyAdmin-related resources, and directory indexing. Applying the prioritized actions above would materially reduce the system's attack surface.

Important: No exploitation was performed. This report is based only on reconnaissance and vulnerability scanning conducted within a controlled educational lab environment.

8. Evidence Files Saved

The scan outputs were saved in the Kali project folder and verified after the scan:

```
(kali@kali)-[~/alfido-project1]
$ ls -l nmap_scan.txt nikto_scan.txt
ls: cannot access 'nikto_scan.txt': No such file or directory
-rw-r--r-- 1 root root 4445 Jul  1 14:54 nmap_scan.txt

(kali@kali)-[~/alfido-project1]
$ sudo ls -l nmap_scan.txt nikto_scan.txt
ls: cannot access 'nikto_scan.txt': No such file or directory
-rw-r--r-- 1 root root 4445 Jul  1 14:54 nmap_scan.txt

(kali@kali)-[~/alfido-project1]
$ cat nikto_scan.txt
cat: nikto_scan.txt: No such file or directory

(kali@kali)-[~/alfido-project1]
$ ls -la
total 24
drwxrwxr-x  2 kali kali 4096 Jul  1 23:42 .
drwx----- 21 kali kali 4096 Jul  1 14:48 ..
-rw-rw-r--  1 kali kali 4325 Jul  1 23:49 nikto_scan.txt.txt
-rw-r--r--  1 root root 4445 Jul  1 14:54 nmap_scan.txt

(kali@kali)-[~/alfido-project1]
$ mv nikto_scan.txt.txt nikto_scan.txt

(kali@kali)-[~/alfido-project1]
$ ls -l nmap_scan.txt nikto_scan.txt
-rw-rw-r-- 1 kali kali 4325 Jul  1 23:49 nikto_scan.txt
-rw-r--r-- 1 root root 4445 Jul  1 14:54 nmap_scan.txt
```

Figure 3. Saved evidence files: nmap_scan.txt and nikto_scan.txt.

nmap_scan.txt | nikto_scan.txt